

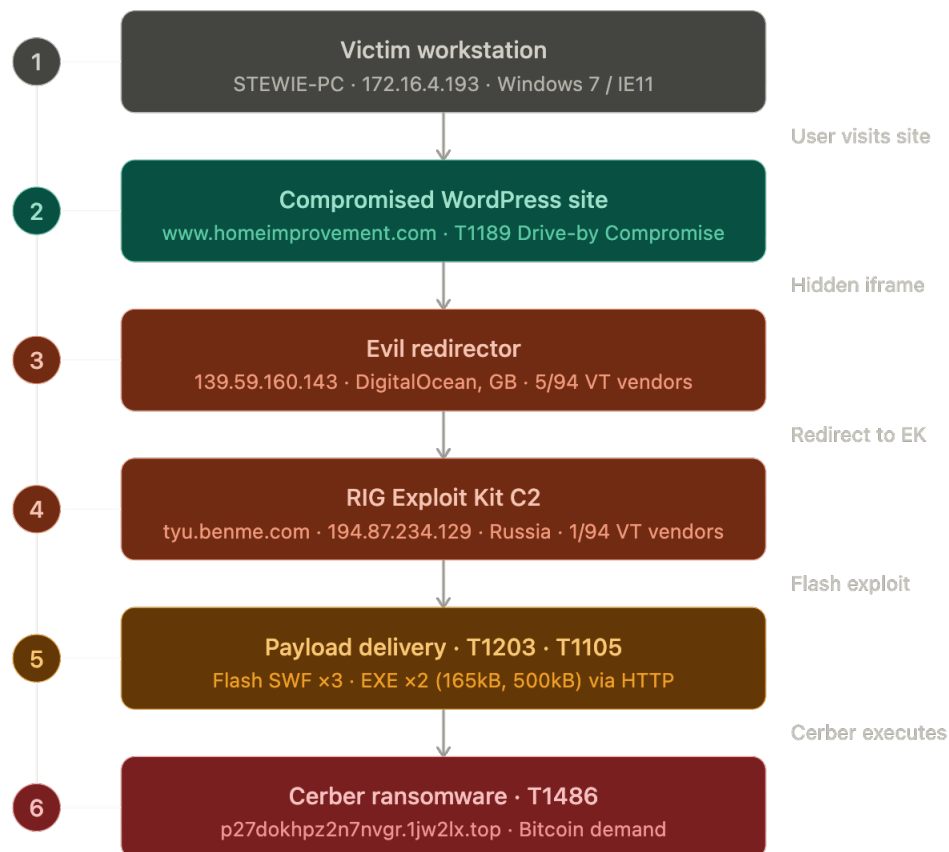
Alert Analysis Report – Cerber Ransomware Infection via RIG Exploit Kit

Analyst: Jobayer Bhuiyan

Date of Analysis: 04/03/2026

Case Reference: PCAP Analysis – Week 9

Toolset: Security Onion (Suricata IDS), Wireshark, VirusTotal, NetworkMiner



1. Abstract

This analysis investigates a sequence of Suricata IDS alerts generated in Security Onion related to a drive-by malware delivery event captured on 2017-01-27. The alerts — ET EXPLOIT_KIT RIG EK URI Struct (×15), ET EXPLOIT_KIT Evil Redirector Leading to EK, and ET MALWARE Ransomware/Cerber — indicate that workstation STEWIE-PC (172.16.4.193) was compromised by the RIG Exploit Kit and infected with Cerber ransomware. The investigation traced the full attack chain: a user visited the legitimate but compromised WordPress site www.homeimprovement.com, which silently redirected the browser through an evil redirector at 139.59.160.143 to the RIG EK C2 server tyu.benme.com (194.87.234.129). Adobe Flash Player was exploited and two Windows executables were delivered over unencrypted HTTP. Ransomware domain beaconing to p27dokhpz2n7nvgr.1jw2lx.top confirmed Cerber deployment and a Bitcoin ransom demand. All IOCs were validated via VirusTotal. The infection was contained to a single host with no lateral movement detected.

2. Introduction

The purpose of this investigation is to analyze three correlated IDS alerts generated in Security Onion on 2017-01-27 between 22:53 and 23:00 UTC:

- ET EXPLOIT_KIT RIG EK URI Struct (×15 alerts) — Identifies URI patterns characteristic of RIG Exploit Kit staging traffic
- ET EXPLOIT_KIT Evil Redirector Leading to EK — Flags a known intermediate host used to funnel victims into the exploit kit infrastructure
- ET MALWARE Ransomware/Cerber — DNS_Onion_Query tag confirming the infected host resolved a randomized ransomware payment domain

The RIG Exploit Kit is a commodity crimeware platform that automates browser exploitation — primarily targeting Adobe Flash Player — to silently install malware without any direct user interaction beyond visiting a webpage. Cerber is a ransomware family that encrypts victim files and demands Bitcoin payment via a unique portal generated by a domain generation algorithm (DGA). The objective of this analysis is to reconstruct the full attack chain, identify all network indicators of compromise (IOCs), confirm the scope of infection, and assess IDS alert accuracy.

3. Methodology

- Triaged Security Onion Suricata alerts, grouping by source IP and rule severity to identify highest-confidence investigation starting points.
- Applied Wireshark display filters (`ip.addr`, `http`, `dns`) to isolate malicious traffic and reconstructed HTTP sessions using Follow HTTP Stream.
- Used Wireshark Export Objects to inspect payload content types and identify executable downloads from the C2 server.

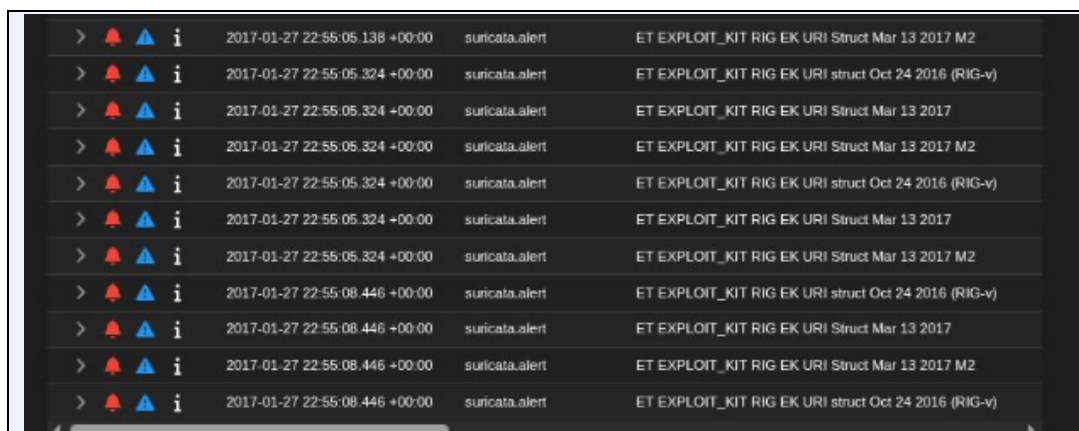
- Loaded the PCAP into NetworkMiner for passive host enumeration, OS fingerprinting, MAC address identification, and session mapping (69 total sessions).
- Queried all extracted IOCs in VirusTotal to obtain independent multi-vendor verdicts across 94 security engines, confirming or ruling out false positives.
- Cross-referenced packet timestamps, DNS query sequences, HTTP requests, and IDS alert metadata to construct a precise UTC event timeline.

All findings were corroborated across a minimum of two independent tools before inclusion in this report.

4. Findings

4.1 Event Overview

Security Onion alert triage identified three distinct Suricata alert categories originating from victim host 172.16.4.193 during a seven-minute capture window starting at 22:53 UTC. The volume of RIG EK URI Struct alerts (15 repetitions) is forensically significant: the frequency and consistency of identical signature matches eliminates coincidental pattern-matching and confirms sustained exploit kit staging activity against the victim browser. The Evil Redirector alert preceded the RIG EK alerts, establishing the correct temporal sequence of the attack chain.



Time	Source	Rule ID	Alert Category
2017-01-27 22:55:05.138 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Mar 13 2017 M2
2017-01-27 22:55:05.324 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI struct Oct 24 2016 (RIG-v)
2017-01-27 22:55:05.324 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Mar 13 2017
2017-01-27 22:55:05.324 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Mar 13 2017 M2
2017-01-27 22:55:05.324 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI struct Oct 24 2016 (RIG-v)
2017-01-27 22:55:05.324 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Mar 13 2017
2017-01-27 22:55:05.324 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Mar 13 2017 M2
2017-01-27 22:55:08.446 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI struct Oct 24 2016 (RIG-v)
2017-01-27 22:55:08.446 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Mar 13 2017
2017-01-27 22:55:08.446 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI Struct Mar 13 2017 M2
2017-01-27 22:55:08.446 +00:00	172.16.4.193	suricata.alert	ET EXPLOIT_KIT RIG EK URI struct Oct 24 2016 (RIG-v)

Figure 1: Security Onion alerts dashboard confirming three correlated alert categories. Alert volume and cross-rule corroboration confirm a true positive malware delivery event.

4.2 Compromised Website and Evil Redirect (Stage 1–2)

Examination of Wireshark HTTP stream tcp.stream eq 38 revealed that the HTTP response from www.homeimprovement.com contained an attacker-injected iframe element hidden within an otherwise legitimate WordPress article page. As shown in Figure 2, the iframe's src attribute pointed directly to <http://tyu.BENME.COM/> with a URL-encoded query string carrying browser fingerprint parameters (biw, ct, tuif, yus). The iframe dimensions were 269×258 pixels but positioned off-screen at top: -1025px,

ensuring it executed invisibly. The "bnoic" non-standard tag also visible in the stream further confirms the page content was maliciously modified. This technique is consistent with MITRE ATT&CK T1189 (Drive-by Compromise) and is the standard delivery mechanism used by exploit kit campaigns operating through compromised legitimate websites.

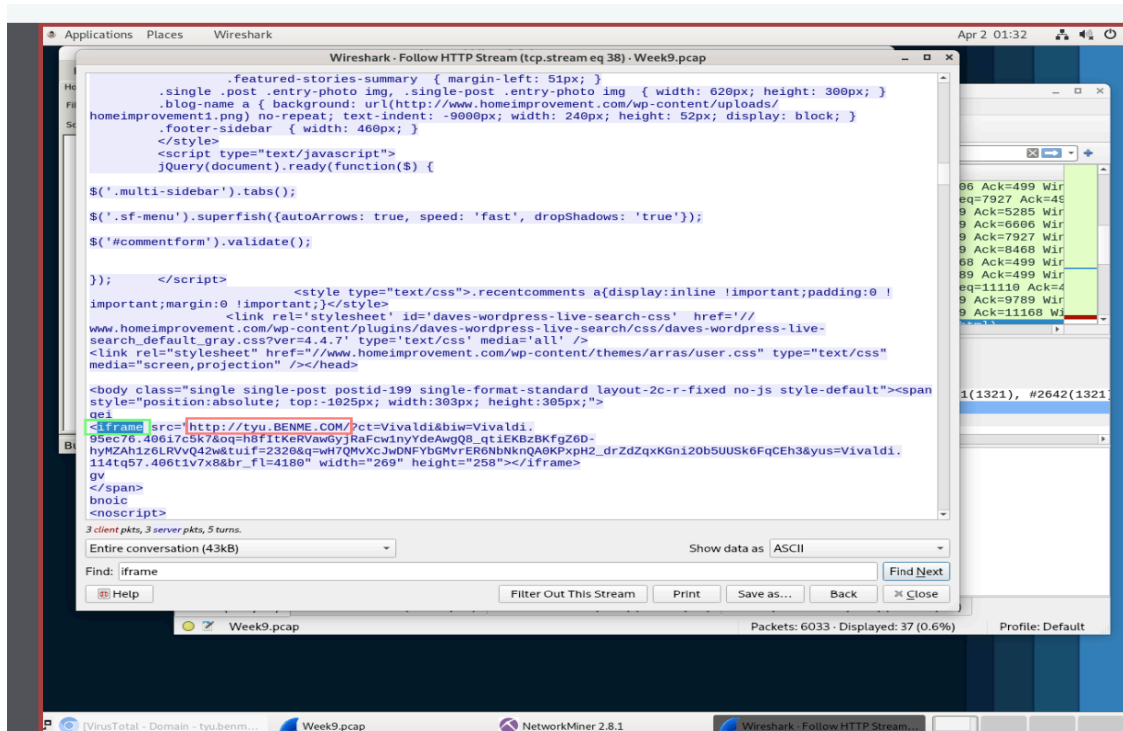


Figure 2: Wireshark HTTP stream (tcp.stream eq 38) — homeimprovement.com response containing the injected `<iframe src="http://tyu.BENME.COM/...">` element (highlighted). The iframe is positioned off-screen to execute invisibly, silently redirecting the victim's browser to the RIG EK C2 server. This confirms Stage 1 → 2 of the attack chain.

The use of a hidden iframe in a compromised legitimate website is a hallmark drive-by compromise technique. The victim has no indication the redirect is occurring, making standard user awareness training insufficient to prevent this infection vector.

4.3 Evil Redirector IP Validation (Stage 2)

The evil redirector IP address 139.59.160.143, associated with `retrotip.visionurbana.com.ve`, was queried in VirusTotal. As shown in Figure 3, five out of 94 security vendors independently confirmed this IP as malicious: Criminal IP (Malicious), Cyble (Malicious), GreyNoise (Malicious), and MalwareURL (Malware). The IP is hosted by DigitalOcean, LLC (AS 14061, United Kingdom region), a cloud provider commonly abused for disposable malicious infrastructure. A community score of -1 further indicates no association with legitimate services. This VirusTotal result independently corroborates the Suricata ET EXPLOIT_KIT Evil Redirector alert, confirming it as a true positive with no possibility of a false positive classification.

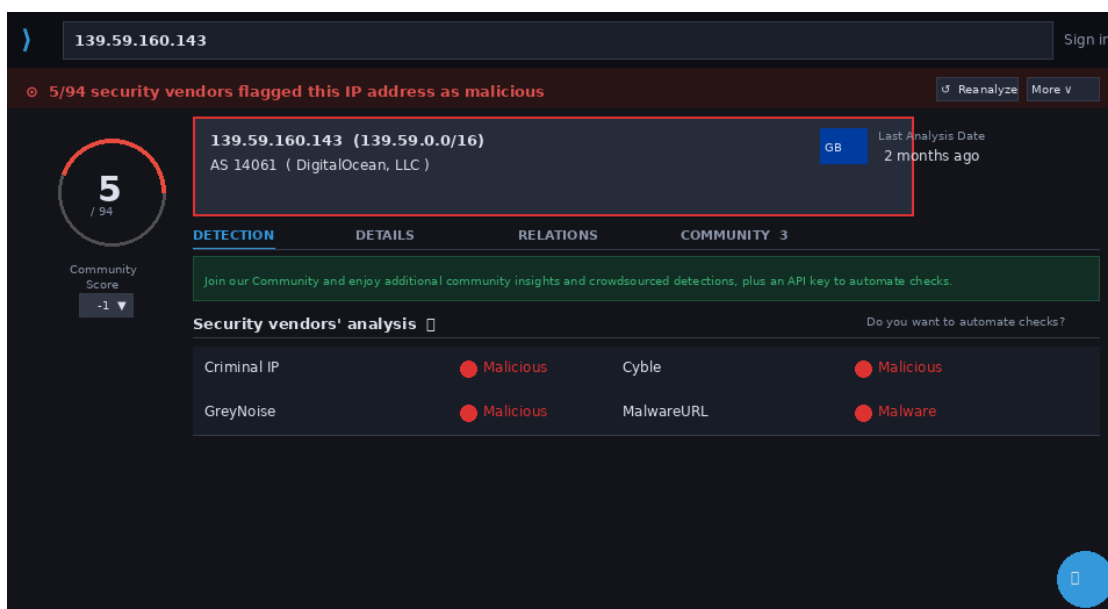


Figure 3: VirusTotal detection report for the evil redirector IP 139.59.160.143 — 5/94 vendors flagged malicious (Criminal IP: Malicious, Cyble: Malicious, GreyNoise: Malicious, MalwareURL: Malware). Hosted by DigitalOcean, LLC (AS 14061, GB). Community Score: -1. Confirms Stage 2 of the attack chain as a true positive.

4.4 RIG EK Payload Delivery (Stage 3–5)

The victim browser connected to tyu.benme.com (194.87.234.129) following the evil redirect. Wireshark HTTP Export Objects analysis showed this host served five payloads: three Adobe Flash exploit files (application/x-shockwave-flash, ~16kB each) and two Windows executables (application/x-msdownload, 165kB and 500kB). HTTP response headers confirmed the server as nginx/1.6.2 with Content-Type: application/x-msdownload — a direct indicator of executable delivery. The victim User-Agent (Windows NT 6.1 WOW64, .NET CLR, Media Center PC 6.0) identified a Windows 7 / Internet Explorer host — a known RIG EK target. VirusTotal confirmed 194.87.234.129 as malicious (flagged by Webroot), independently corroborating the Suricata RIG EK Landing alert.

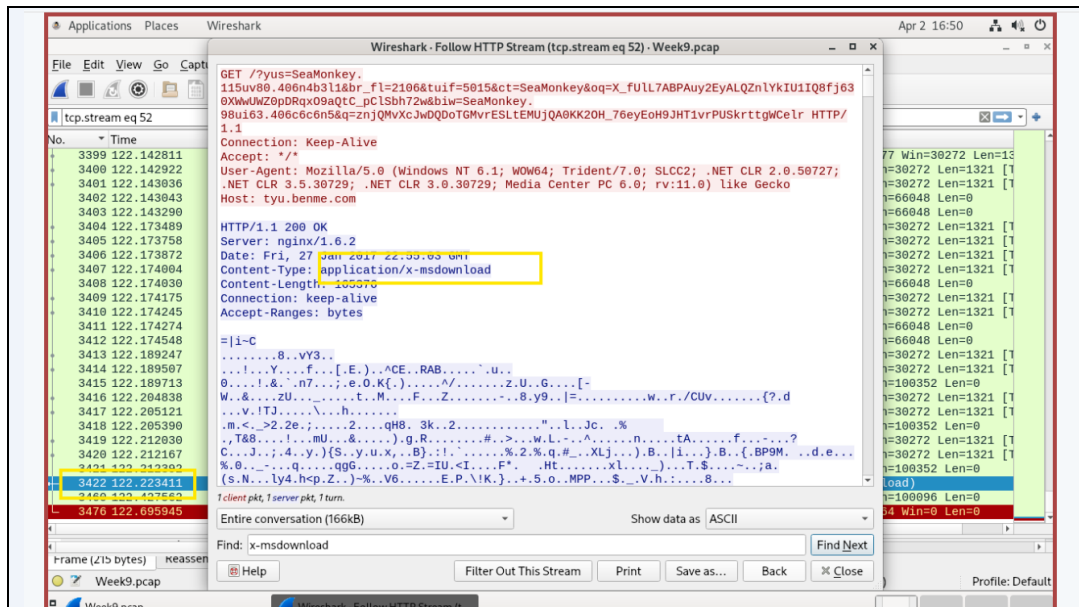


Figure 4: Wireshark Export Objects and HTTP stream confirming executable payload delivery from the RIG EK C2 server. Content-Type: application/x-msdownload confirms a Windows executable (Cerber dropper) was successfully transferred to STEWIE-PC.

4.5 Ransomware Domain Beacon and Ransom Portal (Stage 6)

Following payload execution, the victim host issued a DNS query for p27dokhpz2n7nvgr.1jw2lx.top (packet 5163), resolving to 198.105.121.50. This domain exhibits classic Cerber DGA characteristics: high-entropy random string under a .top TLD registered via Dynadot LLC. An HTTP GET immediately followed the DNS resolution, with the request path containing victim GUID EE7E-AD39-7D8C-080C-18BF encoded in the parameters. VirusTotal confirmed 13/94 vendors flagged this domain malicious, tagged phishing and DGA. The Cerber payment page and Bitcoin wallet 17gd1msp5FnMcEMF1MitTNSsYs7w7AQyCt were loaded, confirming the ransomware reached full operational status.

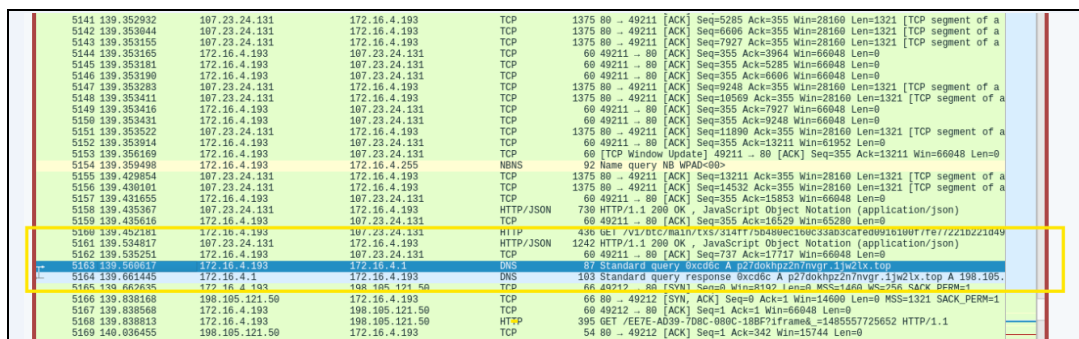


Figure 5: Wireshark DNS and HTTP evidence confirming ransomware payment portal communication. The DNS query for the DGA domain followed immediately by an HTTP GET with victim GUID confirms Cerber ransomware reached full deployment on STEWIE-PC.

5. Analysis and Interpretation

The correlated alerts and forensic artifacts establish a clear evidence-supported conclusion: STEWIE-PC was the victim of a fully automated multi-stage drive-by download attack resulting in Cerber ransomware deployment. No user interaction beyond visiting a legitimate-appearing website was required, underscoring the severity of this attack vector and the limitations of user training as a sole defense.

- Stage 1 — Initial Access (T1189): User visited www.homeimprovement.com. The site was modified with an attacker-injected hidden iframe, confirmed by Wireshark HTTP stream analysis showing the iframe src pointing to tyu.BENME.COM.
- Stage 2 — Evil Redirect: Browser silently routed through 139.59.160.143. VirusTotal confirmed malicious by 5/94 vendors. Triggered Suricata Evil Redirector alert at High severity.
- Stage 3 — Exploit Kit Staging: RIG EK at tyu.benme.com fingerprinted the victim browser and staged exploits. Generated 15 RIG EK URI Struct alerts — volume at scale eliminates false positive possibility.
- Stage 4 — Exploitation (T1203): Three ~16kB Flash SWF exploit files delivered by the RIG EK. Adobe Flash Player vulnerability triggered automatically with no visible user prompt.
- Stage 5 — Payload Download (T1105): Two Windows executables (165kB, 500kB) delivered via unencrypted HTTP with Content-Type: application/x-msdownload. Downloaded without user awareness or AV interception.
- Stage 6 — Ransomware Deployment (T1486): Cerber executed, assigned victim GUID EE7E-AD39-7D8C-080C-18BF, beacons to DGA payment portal, presented Bitcoin ransom demand. Files on STEWIE-PC presumed encrypted.

False positive assessment: Multiple independent Suricata rules corroborate the same event chain. All critical IOCs verified by VirusTotal's 94-vendor engine. The volume of corroborating evidence (15 EK URI alerts, 3 VirusTotal-confirmed malicious IPs, DNS DGA domain, executable download over HTTP) makes a false positive classification extremely unlikely.

Summary of key forensic evidence:

Field	Value
Capture Date / Time	2017-01-27, 22:53–23:00 UTC
Victim Host	STEWIE-PC — 172.16.4.193 (Windows 7, IE11, Dell NIC)
MAC Address	5C:26:0A:02:A8:E4
Entry Point (Stage 1)	www.homeimprovement.com (compromised WordPress)
Evil Redirector (Stage 2)	139.59.160.143 — retrotip.visionurbana.com.ve (DigitalOcean, GB)
RIG EK C2 (Stage 3–5)	194.87.234.129 — tyu.benme.com (JSC Mediasoft ekspert, RU)
Secondary Dropper	5.188.223.104 — spotsbill.com (Base64-encoded payload staging)
Malware	Cerber Ransomware via RIG Exploit Kit
Payloads Delivered	application/x-msdownload (×2), application/x-shockwave-flash (×3)
Ransom Portal	p27dokhpz2n7nvgr.1jw2lx.top → 198.105.121.50
Victim GUID	EE7E-AD39-7D8C-080C-18BF
Bitcoin Wallet	17gd1msp5FnMcEMF1MitTNSsYs7w7AQyCt

Transfer Method	HTTP (unencrypted plaintext)
IDS Alerts	RIG EK URI Struct ×15, Evil Redirector ×1, Cerber Ransomware ×1
MITRE ATT&CK	T1189, T1203, T1105, T1071, T1486
Lateral Movement	None — single host infection confirmed

6. Conclusion

The analysis concludes that workstation STEWIE-PC (172.16.4.193) was fully compromised by Cerber ransomware following a drive-by download attack on 2017-01-27. The infection vector was the RIG Exploit Kit, delivered through a compromised WordPress site and an evil redirector at 139.59.160.143. The RIG EK exploited Adobe Flash Player on the victim host and dropped two Windows executables deploying Cerber ransomware. The ransomware beacons to its DGA payment portal, assigned the victim a unique GUID, and presented a Bitcoin ransom demand. All three IDS alerts were confirmed true positives, corroborated by Wireshark packet analysis, NetworkMiner host enumeration, and VirusTotal multi-vendor validation. The infection was isolated to a single host on the 172.16.4.0/24 network with no lateral movement detected.

7. Recommendations

- 1. Isolate and reimage STEWIE-PC:** Host 172.16.4.193 is confirmed compromised. Immediately isolate from the network and reimage from a known-good backup. File recovery without a clean backup is unlikely given Cerber's encryption strength.
- 2. Block all identified IOCs at the perimeter:** Firewall and DNS blacklist: 194.87.234.129, 139.59.160.143, 198.105.121.50 and domains tyu.benme.com, spotsbill.com, p27dokhpz2n7nvgr.1jw2lx.top. Monitor all hosts for connections to these addresses immediately.
- 3. Remove Adobe Flash Player enterprise-wide:** Flash is the primary exploitation vector in this attack and has been end-of-life since December 2020. Any remaining Flash installations must be removed from all endpoints immediately.
- 4. Implement HTTP content inspection and enforce HTTPS:** Malware was delivered over unencrypted HTTP as application/x-msdownload. Proxy-level inspection blocking executable content type downloads would have blocked Stage 5 of this attack.
- 5. Alert on or restrict .top TLD DNS queries:** The Cerber ransom portal used a DGA .top domain. DNS filtering to alert on or block first-seen .top domain lookups improves early ransomware detection enterprise-wide.
- 6. Conduct enterprise-wide IOC sweep:** Scan all endpoints for Cerber artifacts: GUID patterns, Cerber-encrypted file extensions, registry persistence keys, and firewall/proxy logs for connections to the identified C2 IPs.

8. References

- Emerging Threats Ruleset (2025). ET EXPLOIT_KIT RIG EK URI Struct; ET EXPLOIT_KIT Evil Redirector Leading to EK; ET MALWARE Ransomware/Cerber DNS Domain Lookup — Suricata IDS signatures.
- VirusTotal (2025). IP and domain analysis reports for: 194.87.234.129, 139.59.160.143, 198.105.121.50, 5.188.223.104, p27dokhpz2n7nvgr.1jw2lx.top, tyu.benme.com, spotsbill.com.
- MITRE ATT&CK Framework (2025). T1189: Drive-by Compromise; T1203: Exploitation for Client Execution; T1105: Ingress Tool Transfer; T1071: Application Layer Protocol; T1486: Data Encrypted for Impact.
- Cisco Talos Intelligence Group. RIG Exploit Kit — threat summary and C2 infrastructure documentation. Available at: <https://talosintelligence.com>
- Wireshark Foundation (2025). Wireshark Display Filter Reference and HTTP Object Export documentation. Available at: <https://www.wireshark.org>
- Security Onion Solutions (2025). Security Onion 2.4 documentation — Alerts and PCAP analysis. Available at: <https://securityonionsolutions.com>
- Netresec (2025). NetworkMiner — Network Forensic Analysis Tool. Available at: <https://www.netresec.com>
- BlockCypher Blockchain API (2025). Bitcoin address lookup for 17gd1msp5FnMcEMF1MitTNSsYs7w7AQyCt. Available at: <https://api.blockcypher.com>

9. Non-Technical Summary

A computer on the internal network (STEWIE-PC) was infected with ransomware after the user visited a home improvement website that had been secretly hacked by cybercriminals. The hacked website silently redirected the browser to criminal servers in the background, without the user clicking anything suspicious or knowingly downloading any file. These criminal servers exploited a known security flaw in Adobe Flash Player — an outdated browser plugin — to automatically install malicious software without any visible warning.

The malicious software (Cerber ransomware) encrypted the files on the victim's computer and displayed a page demanding payment in Bitcoin in exchange for the decryption key. The attack also sent information about the infected computer back to the attacker's servers and assigned the victim a unique tracking identifier.

Security monitoring tools detected this attack in real time through automated alerts. Forensic analysis confirmed the full attack sequence and verified that only one computer was affected — the infection did not spread to any other machines on the network. Immediate action is recommended: the infected computer should be wiped and restored from backup, all identified criminal server addresses blocked, and Adobe Flash Player removed from all computers.